TRANSPUTEC

AI PLAYBOOK
NO. 02

PLAYBOOK NO. 02 · RESPONSIBLE AI

Adopt AI without the regret.

Practical governance for leaders who want the benefits of AI without the headlines, the complaints or the clean-up.

INSIDE

Contents

How to put sensible guardrails around AI: who owns it, what the rules are, how to judge risk, protect personal data, keep people in charge and handle the day something goes wrong.

Foreword 03

Introduction 04

01 Governance that people follow 06

02 Judging and managing risk 11

03 Running AI responsibly 18

FOREWORD

Responsible AI is not a brake. It is what lets you keep going.

Most AI regrets are not caused by the technology failing. They are caused by decisions nobody quite made: a tool adopted without checking where the data went, a model trusted with a decision it was never tested for, a customer who was never told a machine was involved.

None of this needs a large compliance function or a thick policy manual. It needs a named owner, a short set of rules people can follow, a sensible way of judging which uses carry real risk, and the habit of checking that the guardrails still work.

This playbook sets out that practical middle ground. It covers governance, acceptable use, data protection under UK GDPR, risk assessment, human oversight, fairness, transparency, supplier checks and incident handling, and shows how the main frameworks fit together. It is written for leaders, not lawyers, so treat it as a guide and take specialist advice where the stakes are high.



The Transputec team
Transputec

INTRODUCTION

Move quickly where it is safe. Slow down where it matters.

Not every use of AI needs the same scrutiny. Drafting an internal email is not the same as screening job applicants or deciding who gets credit. Responsible adoption means matching the effort to the risk, so low-risk use flows freely and high-risk use gets the care it deserves.



Make someone accountable

A named owner, with authority and time, turns good intentions into decisions that actually get made.



Match controls to risk

Light rules for everyday use, deeper assessment for anything affecting people's rights, money or safety.



Keep people in charge

Humans review, decide and answer for the outcomes. AI informs the decision, it does not own it.

The cheapest time to get AI governance right is before the first complaint.

A few clear decisions made early cost far less than unpicking a tool, a dataset or a reputation later.

01

PART 01

Set the rules.

Ownership, a policy people can actually follow and the frameworks worth borrowing from.

01 Why governance pays

02 The four building blocks

03 Frameworks and the acceptable use policy

WHY IT MATTERS

Governance is how you say yes with confidence

> **Clear rules do not slow AI adoption down. Uncertainty does.**

For many leaders, the word governance conjures up committees, forms and delay. With AI, the opposite is usually true. Organisations without clear rules tend to stall, because nobody is sure what is allowed, so cautious people do nothing and bolder people do whatever they like.

Good governance answers a handful of questions so that everyone else does not have to. Which tools are approved? What data can go into them? Which uses need a closer look, and who signs them off? What happens when something goes wrong? Once those answers exist, most AI use can proceed without anyone asking permission.

The risks it guards against are real but ordinary. Personal or confidential data shared with a tool that keeps it. Decisions that treat some groups unfairly. Customers misled about whether they are dealing with a person. Outputs relied on without checking. Contracts that leave you exposed when a supplier changes its terms. Each of these has caught out organisations that were simply moving fast.

Regulation is part of the picture, and it is still taking shape. In the UK, existing law already applies: data protection, equality, consumer protection and sector rules do not pause because AI is involved. The EU has a dedicated AI Act, which can reach UK businesses that sell into the EU. Rules and guidance are changing, so build governance that can absorb change rather than chasing each update.

The good news is that you do not need to invent anything. Established frameworks such as the NIST AI Risk Management Framework and ISO/IEC 42001 set out what good looks like. Most organisations borrow the parts they need and scale them to their size.

Start small and real. One owner, one page of policy, a register of where AI is used and a quarterly review will put you ahead of many organisations, and give you something to build on as use grows.

BUILDING BLOCKS

Four building blocks of AI governance

Get these in place and most of the rest follows. Each can start as a single page and grow with use.



An accountable owner

A senior person who owns AI risk and adoption, with a small group drawn from IT, legal, data protection, HR and the business.



A short policy

An acceptable use policy in plain English: approved tools, data rules, what needs review and where to ask questions.



An AI register

A simple list of where AI is used, by whom, with what data, at what risk level and with what controls.



A regular review

A quarterly look at new uses, incidents, supplier changes and whether the controls still work in practice.

> If you only do one thing this month, name the owner. Everything else depends on someone having the job.

FRAMEWORKS

Frameworks worth borrowing from

You do not need to adopt any of these wholesale. Each offers a useful structure. All are updated over time, so check the current version.

FRAMEWORK	WHAT IT IS	WHAT TO BORROW
UK GDPR and ICO guidance	Data protection law, plus regulator guidance on AI and personal data.	DPIAs, lawful basis, transparency and rights around automated decisions.
UK principles-based approach	Existing regulators apply five principles within their own sectors.	Safety, transparency, fairness, accountability and contestability as review headings.
EU AI Act	A risk-based law with tiers from prohibited uses to minimal risk, phased in over time.	Its risk tiers. Check obligations if you sell into or operate in the EU.
NIST AI RMF	A voluntary US framework built around four functions: govern, map, measure, manage.	A practical structure for your risk process and review cycle.
ISO/IEC 42001	An international, certifiable standard for AI management systems.	Policies, roles and continual improvement, especially if customers ask for assurance.

01



The acceptable use policy

The single most useful governance document you can write. Keep it short enough to read in five minutes, and specific enough to answer real questions.

APPROVED TOOLS

Name the AI tools staff may use for work, how to get access and what to do if they need something not on the list.

DATA RULES

Say plainly what must never go into AI tools, such as customer personal data in unapproved tools, and what is fine.

CHECKING AND ACCOUNTABILITY

Make clear that people own anything they produce with AI, must check it and must not present it as unreviewed fact.

USES THAT NEED SIGN-OFF

List the uses that need review first, such as anything affecting hiring, pay, credit, health or customer decisions.



OWNER

Your AI owner, with HR and data protection

Bring this to the monthly review, with a date for each action.

02

PART 02

Know the risk.

How to sort uses by risk, protect personal data, keep humans in charge and treat people fairly.

01 Risk tiers and assessment

02 Data protection under UK GDPR

03 Oversight, fairness and transparency

RISK TIERS

Sort every use by impact and autonomy

Two questions decide how much scrutiny a use needs: how much harm could a wrong output cause, and how far does it act without a person checking?

↑ IMPACT ON PEOPLE

ASSESS CAREFULLY

High impact, human decides

Hiring, credit, health or legal support where a trained person makes the call. Needs a full assessment.

HIGHEST SCRUTINY

High impact, AI acts alone

Automated decisions about people. Restricted by law in many cases. Senior sign-off, or do not do it.

ALLOW FREELY

Low impact, human decides

Drafting, summarising and research that a person reviews. Covered by the acceptable use policy.

CONTROL AND MONITOR

Low impact, AI acts alone

Routing, tagging or simple automations. Fine with testing, monitoring and an easy way to correct errors.

AUTONOMY OF THE AI →

DATA PROTECTION

Personal data does not stop being personal inside an AI tool

> **If you would need a DPIA for a new system, you need one for a new AI system.**

If an AI system processes personal data, UK GDPR applies in full. That covers obvious cases such as analysing customer records, and less obvious ones such as staff pasting emails, CVs or meeting notes into an assistant.

Start with the basics you already know. You need a lawful basis for the processing, and you must be able to explain it. Use only the data you need for the purpose. Tell people how their data is used, in language they can understand. Keep it secure, keep it no longer than necessary, and make sure people can still exercise their rights.

A data protection impact assessment is required where processing is likely to result in a high risk to individuals, and AI often meets that bar. Even where it is not strictly required, a short DPIA is the most practical way to think through what data is used, what could go wrong and what controls you need. The ICO publishes guidance on AI and data protection that is worth reading alongside it.

Pay particular attention to decisions made solely by automated means that have legal or similarly significant effects, such as refusing credit or rejecting a job applicant. The law gives people specific protections here, including the right to human involvement and to contest the outcome. These rules have been updated by recent legislation, so check current ICO guidance before relying on an automated decision.

Suppliers matter too. When you use an AI service, the provider usually acts as your processor, so you need a contract that covers how they handle the data, which sub-processors they use, where data is stored and whether it can be used to train their models. Business editions and consumer editions of the same tool often have very different terms.

Finally, think about what goes in by accident. Clear rules, approved tools and simple training prevent most problems, because most data leaks into AI tools are well-meaning colleagues trying to save time.

RISK ASSESSMENT

A proportionate assessment in five steps

Use this for any use that lands outside the low-risk corner. For most uses it fits on two pages.

Describe

What the AI does, who uses it, who it affects and what decision or output it feeds.

Map the data

What data goes in, where it is processed and stored, and whether any of it is personal or confidential.

Find the harms

What happens if it is wrong, biased, unavailable or misused, and who would be affected.

Set controls

Human review, testing, access limits, monitoring and a way for people to challenge outcomes.

Decide and record

The owner approves, rejects or asks for changes, and sets a date to review it.

> **Record the decision in your AI register, with the owner and the review date. An undocumented approval is hard to defend.**

HUMAN OVERSIGHT

Oversight that works, and oversight on paper

Putting a person in the loop only helps if they have the time, skill and authority to disagree with the machine.

ASPECT	OVERSIGHT ON PAPER	OVERSIGHT THAT WORKS
Time	Reviewers approve dozens of outputs an hour.	Review time is planned and protected for the cases that matter.
Information	The reviewer sees only the AI's answer.	The reviewer sees the inputs, the reasoning and the confidence.
Authority	Overriding the AI needs a justification.	Disagreeing is normal and the reviewer's call stands.
Skill	Anyone available signs off.	Reviewers are trained in the task and in common AI failure modes.
Feedback	Overrides disappear into a queue.	Overrides are logged and used to improve the system.

IN PRACTICE

Three uses that need more than a policy

HR

Screening job applications

THE RISK

Unfair treatment of candidates and discrimination claims under the Equality Act.

KEY CONTROLS

DPIA, bias testing across groups, human review of every rejection.

TELL PEOPLE

Explain to applicants that AI is used and how to ask for a human review.

WATCH OUT

Historical hiring data can teach a model old biases.

CUSTOMER SERVICE

A chatbot answering customers

THE RISK

Wrong answers given with confidence, and customers misled about who they are talking to.

KEY CONTROLS

Answers drawn from approved content, clear limits and an easy route to a person.

TELL PEOPLE

Say plainly that it is an AI assistant, at the start of the conversation.

WATCH OUT

Promises the bot makes may be treated as promises your business made.

FINANCE

Prioritising debt collection

THE RISK

Vulnerable customers treated harshly by an automated score.

KEY CONTROLS

Senior sign-off, regular outcome reviews and checks for vulnerability.

TELL PEOPLE

Explain how decisions are made and how to challenge them.

WATCH OUT

Sector regulators expect good customer outcomes whatever tool you use.

FAIRNESS AND TRANSPARENCY

What good looks like for fairness and openness

Two areas where intent is not enough. You need evidence that outcomes are fair and that people understand what is happening.

AREA	WHAT TO DO	EVIDENCE TO KEEP
Bias testing	Test outcomes across groups before launch and at intervals afterwards.	Test results, the groups checked and actions taken.
Training data	Ask what the model learned from, and whether it reflects your users.	Supplier answers and your own sample checks.
Telling people	Say when AI is used in a way that affects them.	The wording used and where it appears.
Explaining outcomes	Be able to explain the main factors behind a decision in plain terms.	A standard explanation and the reviewer's notes.
Challenge and redress	Give people a simple way to question an outcome and reach a person.	Complaints, reviews and how they were resolved.

03

PART 03

Keep it right.

Choosing suppliers you can trust, handling incidents calmly and making good habits stick.

01 Supplier due diligence

02 When AI gets it wrong

03 Principles that last

SUPPLIER CHECKS

Due diligence for every AI supplier

Proportionate checks before you sign, scaled to the risk of the use. Ask in writing and compare answers with the contract.

01 Confirm the use and the data

Be clear what the tool will do and what data it will see, so you ask the right questions.

02 Check data terms

Training use, retention, location, sub-processors and deletion, confirmed in the contract.

03 Ask how they test

How the supplier tests for accuracy, bias and misuse, and how often models change.

04 Look for assurance

Independent certifications, security documentation and help with your own DPIA.

05 Plan for change and exit

Notice of model or term changes, and how you leave with your data.

06 Record and review

Add the supplier to your AI register with an owner and a renewal check.

REMEMBER

The same tool can carry very different terms in its consumer and business editions. Check which one your people are actually using.

INCIDENTS

When AI gets it wrong

Something will go wrong eventually. A calm, rehearsed response limits the harm and builds trust. Fold these steps into the incident process you already have.



Make it easy to report

Staff and customers need an obvious way to flag a bad output, an unfair outcome or data in the wrong place.



Know how to pause

Decide in advance who can switch off a tool or feature, and how quickly it can be done.



Find the cause

Was it the data, the model, the prompt, the process or the person? The fix depends on the answer.



Meet your duties

Personal data breaches may need reporting to the ICO within strict deadlines. Affected people may need telling.

> **Treat near misses as gifts. Each one shows you a weak control before it causes real harm.**

PRINCIPLES

Five habits of responsible AI adopters

Organisations that avoid AI regrets tend to share the same habits, regardless of size or sector.

01 **Be proportionate**

Spend scrutiny where the impact on people is highest, and let everyday use flow.

02 **Keep a person answerable**

Every AI-assisted decision has a named human owner who can explain it.

03 **Be open by default**

Tell people when AI is involved in decisions about them, and how to reach a person.

04 **Train for judgement**

Teach people what the policy says and why, and how to spot a wrong or unfair output.

05 **Review and adapt**

Revisit uses, suppliers and rules regularly. The technology and the law both keep moving.

ASK YOUR TEAM

Questions for your leadership team

Work through these together. Uncomfortable silences point to where to start.

OWNERSHIP AND RULES

- ? Who is accountable for AI risk here, and do they have the time and authority to act?
- ? Could every colleague tell us which AI tools are approved and what data is off limits?
- ? Do we know everywhere AI is being used today, including inside software we already own?

PEOPLE AND OUTCOMES

- ? Which of our AI uses affect decisions about customers, staff or applicants?
- ? Have we tested those uses for unfair outcomes, and when did we last check?
- ? If someone challenged an AI-assisted decision tomorrow, could we explain it and put it right?

CHECKLIST

Are you adopting AI responsibly?

Tick what is in place today. Anything left blank is your next action.

- [ ] **A named, senior owner for AI risk**
  With a small cross-functional group.

- [ ] **A short acceptable use policy, published and understood**
  Approved tools, data rules and uses needing sign-off.

- [ ] **An AI register**
  Every use, its data, risk level, owner and review date.

- [ ] **DPIAs for higher-risk uses**
  Completed before launch, not after.

- [ ] **Human review designed in**
  With time, information and authority to override.

- [ ] **Supplier terms checked**
  Training use, retention, location and exit.

- [ ] **An incident route that covers AI**
  Report, pause, investigate and notify.

This checklist is a starting point, not legal advice. Take specialist advice for high-risk or regulated uses.

GLOSSARY

Words worth knowing

AI governance

The roles, rules and reviews that decide how AI is used in an organisation.

Acceptable use policy

The plain-language rules for how staff may use AI tools and data.

AI register

A record of every AI use, its data, risk level, owner and controls.

DPIA

Data protection impact assessment, used to assess and reduce risks to individuals from processing personal data.

Automated decision

A decision made without meaningful human involvement. Special legal protections apply where effects are significant.

Human in the loop

A person reviews and can change AI output before it is used.

Bias

Systematic differences in outcomes that disadvantage particular groups.

Processor

A supplier that processes personal data on your behalf and under your instructions.

NIST AI RMF

A voluntary US framework for managing AI risk: govern, map, measure, manage.

ISO/IEC 42001

An international, certifiable standard for AI management systems.

EU AI Act

The EU's risk-based AI law, which can apply to UK firms serving EU markets.

Contestability

People's ability to challenge an AI-assisted outcome and reach a person.

TRANSPUTEC

Adopt AI with a clear conscience.

We help organisations set up practical AI governance, from acceptable use policies and AI registers to supplier checks and secure, well-configured tools.

Book an AI governance session

transputec.com

ALSO IN THE SERIES

No. 03 · Open weights, open questions